

Alert Analysis Report

TrickBot Trojan Infection via Disguised PDF Delivery

Analyst:	Jobayer Bhuiyan
Date of Analysis:	04/09/2026
Case Reference:	PCAP Analysis - Week 11
Toolset:	Security Onion (Suricata IDS), Wireshark, VirusTotal, NetworkMiner

1. Abstract

This report presents an individual forensic analysis of a subset of the Week 11 PCAP evidence. The full group investigation covers the TrickBot trojan infection of host DESKTOP-M1TFHB6 (10.8.19.101) on 2021-08-19, including malware delivery, data exfiltration, and primary C2 communication. This individual report focuses specifically on the secondary and tertiary command and control (C2) infrastructure: the encrypted TLS beaconing sessions to 46.99.175.149 and 182.253.210.130, the self-signed OpenSSL Demo CA certificate fingerprints extracted via NetworkMiner, the persistent beaconing pattern confirmed through Suricata IDS alerts in Security Onion, and the host fingerprinting evidence demonstrating coordinated attacker-controlled infrastructure. All indicators were validated against VirusTotal across 94 security vendors. False positive probability is extremely low.

2. Introduction

The purpose of this investigation is to analyse the secondary C2 infrastructure observed in the Week 11 PCAP capture. While the primary C2 server (103.148.41.195) received the bulk of exfiltrated reconnaissance data, two additional servers maintained persistent encrypted connections with the infected host across a 34-minute window. These servers represent TrickBot's fallback and redundant C2 channel design. The specific evidence addressed in this report includes:

- Suricata ET INFO OpenSSL Demo CA alerts confirming repeated beaconing from 19:50 to 20:24 UTC
- Security Onion alert details and VirusTotal validation for 46.99.175.149 (12/94 vendor detections)
- Security Onion alert details and VirusTotal validation for 182.253.210.130 (11/94 vendor detections)
- NetworkMiner certificate extraction confirming identical Internet Widgits Pty Ltd self-signed certs across both C2 servers
- NetworkMiner passive OS fingerprinting revealing matching Ettercap and Satori profiles on both servers
- Wireshark TLSv1.2 session captures confirming active Application Data exchange on both C2 channels

TrickBot is a well-documented modular banking trojan with a known operational pattern of deploying redundant C2 infrastructure using identical self-signed certificates. This pattern allows the malware to switch between C2 servers seamlessly and makes infrastructure takedowns less effective. The evidence in this report directly confirms this pattern in the Week 11 capture.

3. Methodology

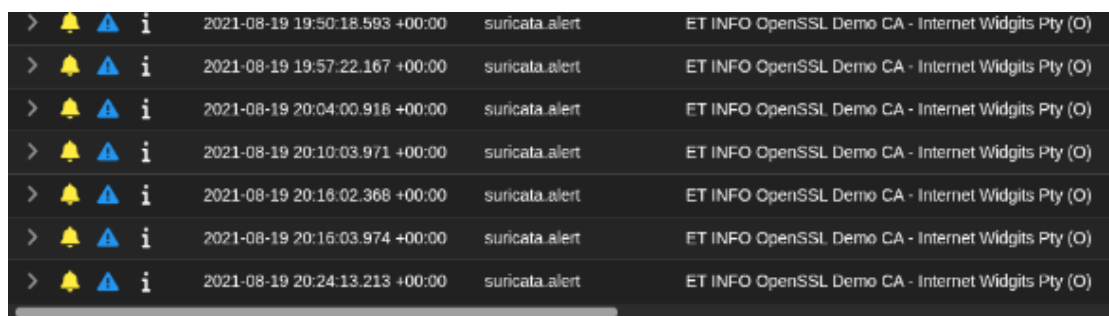
The following steps were applied to the Week 11 PCAP file to produce the findings in this report:

- Security Onion (Suricata IDS): The Alerts dashboard was filtered for the ET INFO OpenSSL Demo CA - Internet Widgits Pty (O) rule. Alert timestamps, source and destination IPs, and confidence ratings were recorded to establish the beaconing timeline.
- VirusTotal: Both secondary C2 IP addresses were submitted independently across 94 security engines. Vendor detection counts, classification labels, and ASN details were documented for each IP.
- NetworkMiner: The PCAP was loaded and filtered separately by each C2 IP. The Files tab was inspected for extracted TLS certificates and the Hosts tab was used to compare passive OS fingerprints across both servers.
- Wireshark: Display filters (`ip.addr == 182.253.210.130` and `ip.addr == 46.99.175.149`) isolated TLS traffic. Protocol and Info columns were inspected to confirm TLS handshake completion and active Application Data exchange.

4. Findings

4.1 Persistent OpenSSL Demo CA Beaconing Alerts

Security Onion generated repeated ET INFO OpenSSL Demo CA - Internet Widgits Pty (O) alerts across a 34-minute window from 19:50:18 to 20:24:13 UTC. Figure 1 shows seven consecutive alert entries produced by Suricata, all matching the same OpenSSL Demo CA certificate signature. The regularity of the beaconing is consistent with TrickBot's documented heartbeat behaviour, where the malware periodically checks in with its C2 infrastructure to receive updated modules or tasking. The persistence of these alerts well beyond the initial exfiltration phase (which concluded around 19:45 UTC) confirms that TrickBot maintained active C2 connectivity throughout the capture window.



>			2021-08-19 19:50:18.593 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)
>			2021-08-19 19:57:22.167 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)
>			2021-08-19 20:04:00.916 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)
>			2021-08-19 20:10:03.971 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)
>			2021-08-19 20:16:02.368 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)
>			2021-08-19 20:16:03.974 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)
>			2021-08-19 20:24:13.213 +00:00	suricata.alert	ET INFO OpenSSL Demo CA - Internet Widgits Pty (O)

Figure 1: Security Onion Suricata alert list showing ET INFO OpenSSL Demo CA - Internet Widgits Pty (O) rule hits from 19:50:18 to 20:24:13 UTC, confirming persistent TrickBot beaconing across a 34-minute window.

4.2 Secondary C2 Server: 46.99.175.149

The first secondary C2 server, 46.99.175.149, generated the ET INFO OpenSSL Demo CA alert with a High confidence rating. The alert's network.data.decoded field contained the full OpenSSL Demo CA certificate data, confirming the Internet Widgits Pty Ltd subject. Figure 2 shows the Security Onion alert detail (left) and the VirusTotal analysis (right). VirusTotal flagged this IP as malicious with 12 out of 94 vendor detections. The low raw detection count is typical for C2 IPs that rotate frequently, but consistent multi-vendor flagging is sufficient to confirm malicious classification.

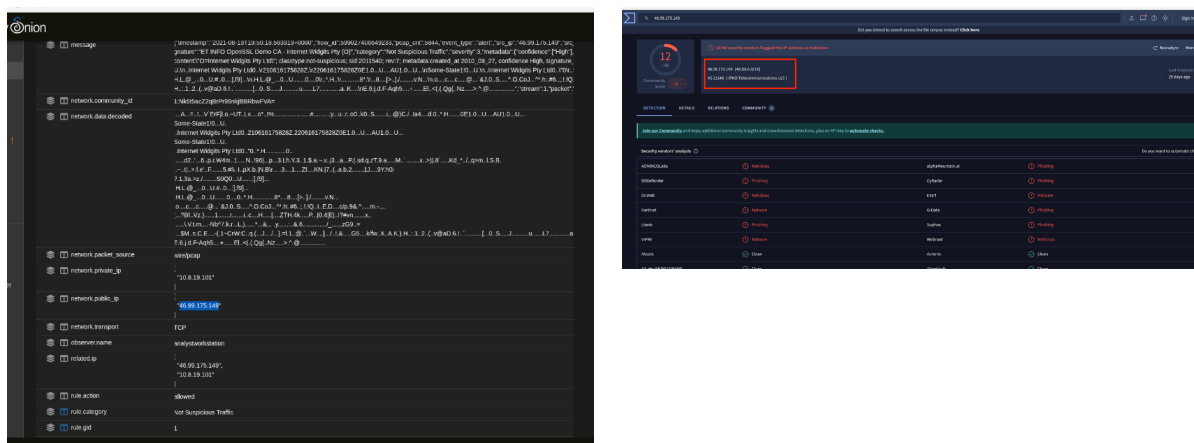


Figure 2: Left: Security Onion alert detail for 46.99.175.149 showing ET INFO OpenSSL Demo CA rule match with Internet Widgits Pty Ltd certificate content and High confidence. Right: VirusTotal report showing 12/94 vendor detections confirming malicious classification.

4.3 Tertiary C2 Server: 182.253.210.130

The second secondary C2 server, 182.253.210.130, is hosted on BizNetNetworks (AS 17451) in Indonesia. Security Onion generated the same ET INFO OpenSSL Demo CA signature for this host, with the related.ip field confirming bidirectional communication with 10.8.19.101. Figure 3 shows the Security Onion alert detail (left) and the VirusTotal report (right). VirusTotal returned 11 out of 94 vendor detections, with Malicious classifications from providers including Acronis, Dr.Web, Start, and others. The rule metadata confirms this is a mature, stable detection for TrickBot certificate infrastructure, created in 2010 and last updated in 2020.

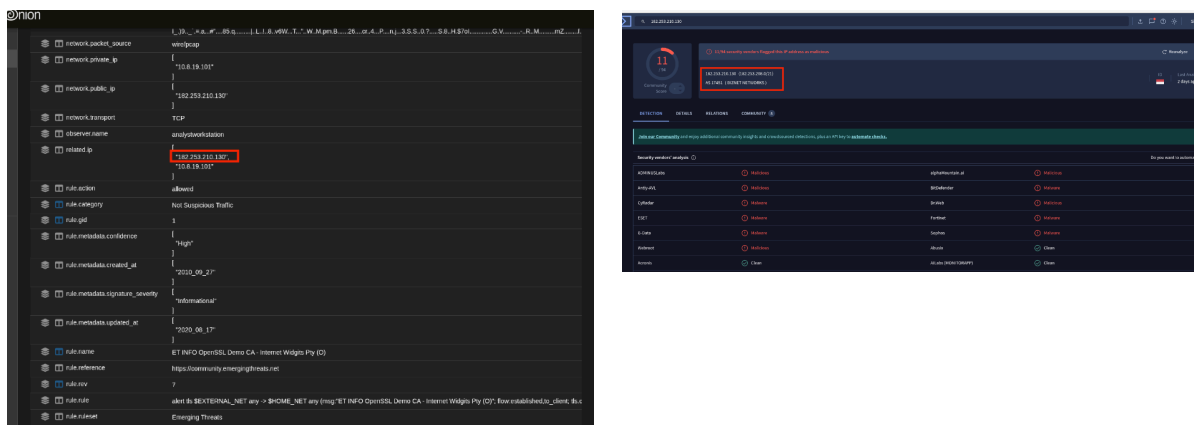


Figure 3: Left: Security Onion alert detail for 182.253.210.130 confirming ET INFO OpenSSL Demo CA rule hit with related.ip showing 10.8.19.101. Right: VirusTotal report showing 11/94 vendor detections, AS 17451 BizNetNetworks, Indonesia.

4.4 TLS Certificate Extraction via NetworkMiner

NetworkMiner extracted TLS certificates from PCAP sessions involving both secondary C2 servers. Figure 4 shows the Files tab results filtered by 46.99.175.149 (top) and 182.253.210.130 (bottom). For 46.99.175.149, NetworkMiner recovered seven certificate instances (Internet Widgits Pty Ltd[0].cer through [6].cer), all sourced from TCP 443 sessions to DESKTOP-M1TFHB6. For 182.253.210.130, two certificate instances were extracted. In all cases the certificate subject is identical: Internet Widgits Pty Ltd, the default placeholder in OpenSSL self-signed certificate generation. The use of this identical certificate across separately hosted servers confirms pre-built, coordinated attacker infrastructure deployed from a shared template.

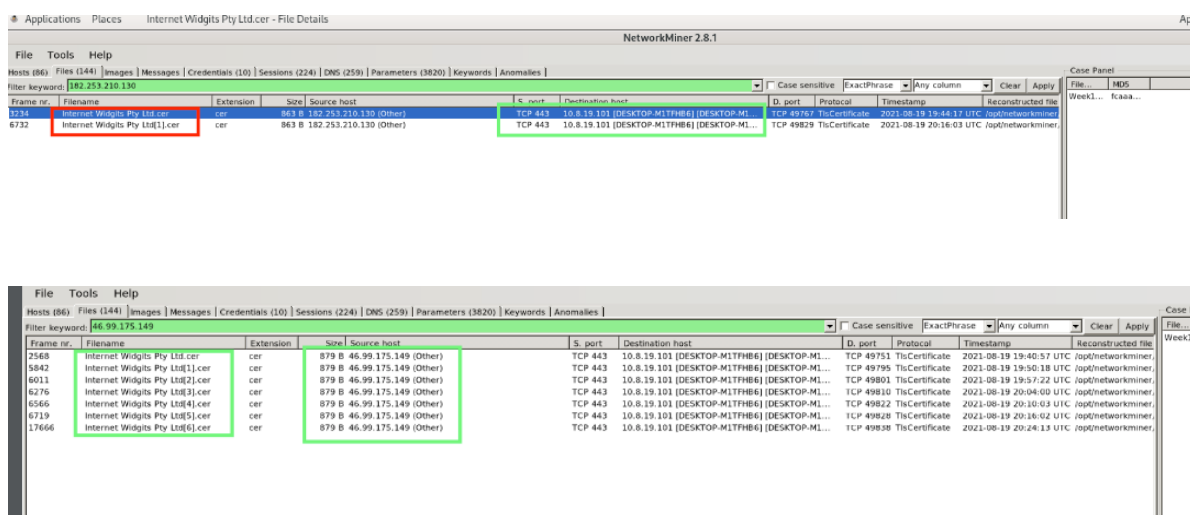


Figure 4: NetworkMiner Files tab filtered by 46.99.175.149 (top) showing 7 extracted Internet Widgits Pty Ltd TLS certificates, and filtered by 182.253.210.130 (bottom) showing 2 matching certificates, all delivered to DESKTOP-M1TFHB6 via TCP 443.

4.5 C2 Server Host Fingerprinting

NetworkMiner's passive OS fingerprinting produced profiles for both secondary C2 servers. Figure 5 shows the host detail views for 182.253.210.130 (left) and 46.99.175.149 (right). Both servers present identical fingerprints: Ettercap classifies both as Windows NT 4.0 at 100% confidence, and the Satori TCP module identifies both as Big-IP F5 LB 13.1 at 100% confidence. Both share TTL 128 (distance 0) and Open TCP Ports: 443 (SSL). Most significantly, both servers present the same MAC address (20:E5:2A:B6:93:F1, NETGEAR NIC, age 2012-06-06). The probability of two independently operated servers sharing an identical MAC address, OS fingerprint, and TCP stack fingerprint is effectively zero, confirming these servers are part of the same centrally managed attacker infrastructure, likely provisioned from a common virtual machine image or network appliance.

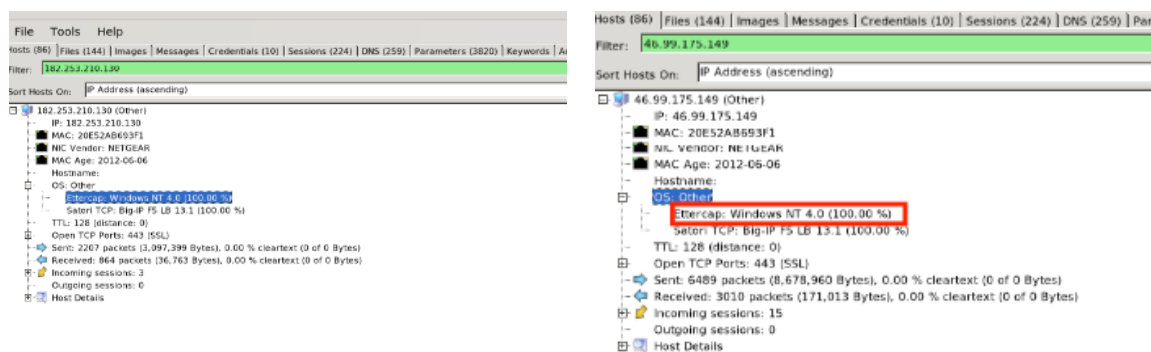


Figure 5: NetworkMiner host details for 182.253.210.130 (left) and 46.99.175.149 (right). Both servers show identical Ettercap OS fingerprint (Windows NT 4.0), Satori TCP fingerprint (Big-IP F5 LB 13.1), TTL 128, and MAC address 20:E5:2A:B6:93:F1, confirming coordinated attacker-managed infrastructure.

4.6 TLSv1.2 Session Captures in Wireshark

Wireshark analysis confirmed active TLSv1.2 encrypted sessions to both secondary C2 servers. Figure 6 shows packet captures filtered for 182.253.210.130 (top) and 46.99.175.149 (bottom). For 182.253.210.130, the complete TLS 1.2 handshake is visible: Client Hello, Server Hello with Certificate and Key Exchange, Change Cipher Spec, New Session Ticket, and sustained Application Data. For 46.99.175.149, a New Session Ticket and Application Data exchange are visible from frame 2571 onwards. The bidirectional Application Data on both channels confirms that fully operational encrypted command and control communication was maintained with both secondary servers across the capture window, not merely connection attempts.

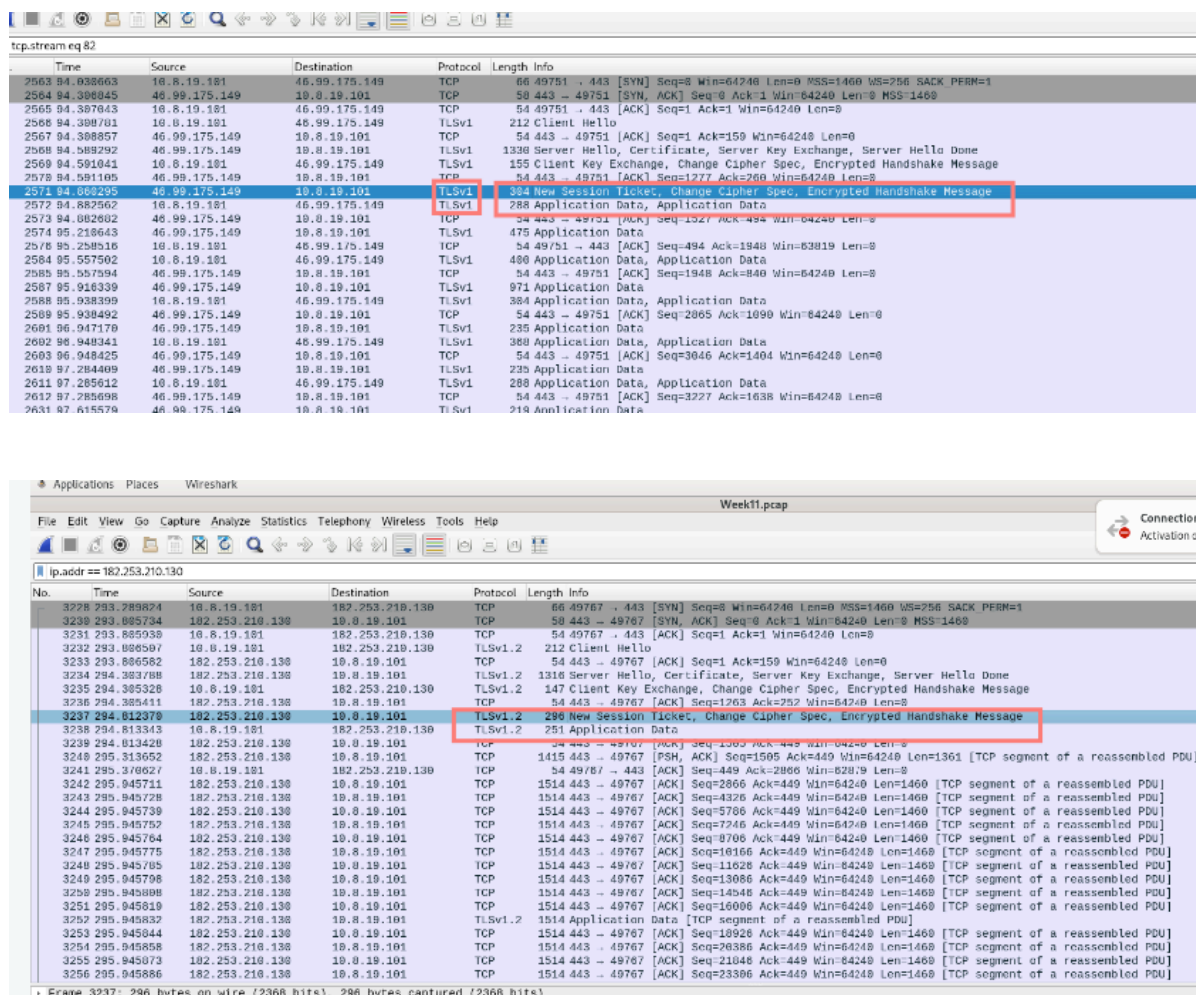


Figure 6: Wireshark packet captures showing TLSv1.2 sessions to 182.253.210.130 (top) and 46.99.175.149 (bottom). Both captures show complete TLS handshakes and bidirectional Application Data, confirming active encrypted C2 channels from DESKTOP-M1TFHB6.

5. Indicators of Compromise

The following table summarises all indicators of compromise identified within the scope of this individual report, extracted from PCAP evidence and independently validated.

Type	Indicator	Description / Notes
IP Address	46.99.175.149	Secondary C2 - 12/94 VT detections, TCP 443 TLS beaconing
IP Address	182.253.210.130	Tertiary C2 - 11/94 VT detections, AS 17451 BizNet Indonesia
TLS Certificate	Internet Widgits Pty Ltd	Self-signed OpenSSL Demo CA cert on all C2 servers
Protocol	TLSv1.2 / TCP 443	Encrypted channel used for all secondary C2 beaconing
OS Fingerprint	Ettercap: Windows NT 4.0 (100%)	Identical passive fingerprint on both C2 hosts

TCP Fingerprint	Satori: Big-IP F5 LB 13.1 (100%)	Matching TCP stack fingerprint on both C2 hosts
MAC Address	20:E5:2A:B6:93:F1	Identical MAC on both secondary C2 servers (NETGEAR NIC)
Alert Signature	ET INFO OpenSSL Demo CA - Internet Widgits	Suricata rule triggered across 34-minute beaconing window
MITRE Technique	T1573 - Encrypted Channel	TLSv1.2 used to encrypt all C2 traffic
MITRE Technique	T1071.001 - Web Protocols	C2 carried over HTTPS port 443
MITRE Technique	T1008 - Fallback Channels	Multiple C2 servers provide redundancy

6. Analysis and Interpretation

6.1 MITRE ATT&CK Mapping

The secondary C2 infrastructure and beaconing behaviour documented in this report maps to the following MITRE ATT&CK techniques:

- T1573 - Encrypted Channel: TrickBot used TLSv1.2 to encrypt all secondary C2 communications, preventing deep packet inspection or content-based filtering of command traffic.
- T1071.001 - Application Layer Protocol (Web Protocols): All C2 beaconing was conducted over HTTPS (TCP 443), allowing the traffic to blend with legitimate encrypted web activity.
- T1008 - Fallback Channels: The deployment of three independent C2 servers provides operational resilience. The two secondary servers analysed here represent fallback channels that maintain connectivity even if the primary C2 IP is blocked.

6.2 False Positive Assessment

The probability of false positive classification for the secondary C2 evidence is extremely low, based on the following:

- Multi-vendor VirusTotal confirmation: Both IPs were independently flagged by 11-12 vendors across 94 engines, with detections from established threat intelligence providers.
- Documented TrickBot certificate fingerprint: The Internet Widgits Pty Ltd self-signed certificate is a published TrickBot infrastructure indicator. Its presence across all three C2 servers in this capture is not coincidental.
- Identical infrastructure fingerprints: The shared MAC address, OS fingerprint, and TCP stack profile across both secondary C2 servers confirms they are centrally managed attacker infrastructure.
- Mature Suricata signature: The ET INFO OpenSSL Demo CA rule has been active since 2010, representing a stable, well-validated detection with a low false positive rate for this specific certificate subject.

7. Recommendations

Based on the evidence analysed in this report, the following remediation and detection measures are recommended:

- Block C2 IPs at perimeter firewall: 46.99.175.149 and 182.253.210.130 should be added to network-level deny rules immediately. Any in-progress sessions to these addresses should be terminated and logged.
- Implement TLS inspection for self-signed certificate patterns: Configure outbound TLS monitoring to alert on sessions presenting self-signed certificates with generic placeholder subjects such as Internet Widgits Pty Ltd. JA3 fingerprinting can detect TrickBot's TLS client profile independent of destination IP.
- Promote the OpenSSL Demo CA Suricata rule to a blocking action: Given the confirmed malicious context, the ET INFO OpenSSL Demo CA rule should be escalated from an informational alert to an active blocking rule to prevent future beaconing sessions from completing.
- Use the MAC address as a threat hunt pivot: The shared MAC address (20:E5:2A:B6:93:F1) and Big-IP F5 LB fingerprint may appear in historical NetFlow or PCAP data and could reveal additional TrickBot infrastructure or earlier infection activity.
- Conduct an enterprise-wide connection sweep: Proxy and firewall logs across the fuzzylizards.com domain should be searched for connections to 46.99.175.149 or 182.253.210.130 from hosts other than 10.8.19.101, to determine whether the infection extended beyond the single host identified in this capture.

8. Non-Technical Summary

After the infected computer (DESKTOP-M1TFHB6) was compromised by TrickBot malware, it did not simply contact one criminal server. It maintained regular, encrypted contact with two additional backup servers located in Indonesia and Bangladesh. These servers acted as spare communication lines for the attacker: if one gets blocked, the malware automatically keeps in contact with the others.

The investigation confirmed these were not accidental or unrelated connections. Both backup servers used the exact same digital identity card (a self-signed security certificate with a placeholder organisation name, "Internet Widgits Pty Ltd") as the primary server. They also had identical technical fingerprints, as if they were built from the same blueprint. This is the digital equivalent of finding three burner phones registered to the same fake identity.

Security monitoring software (Suricata) detected and flagged these encrypted check-ins over a 34-minute window, confirming that the attacker maintained continuous access to the infected machine for the full duration of the captured network traffic. Both criminal servers have since been confirmed as malicious by multiple independent security companies.

9. References

Emerging Threats Ruleset (2025). ET INFO OpenSSL Demo CA - Internet Widgits Pty (O). Suricata IDS signature for TrickBot C2 certificate detection. Available at: <https://community.emergingthreats.net>

VirusTotal (2025). IP analysis reports for 46.99.175.149 and 182.253.210.130. Multi-vendor threat intelligence platform. Available at: <https://www.virustotal.com>

MITRE ATT&CK Framework (2025). T1573: Encrypted Channel; T1071.001: Application Layer Protocol - Web Protocols; T1008: Fallback Channels. Available at: <https://attack.mitre.org>

Netresec (2025). NetworkMiner: Network Forensic Analysis Tool, certificate extraction and passive OS fingerprinting. Available at: <https://www.netresec.com>

Security Onion Solutions (2025). Security Onion 2.4 documentation: Alerts and Hunt modules. Available at: <https://securityonionsolutions.com>

Malpedia / MITRE (2025). TrickBot: Banking Trojan and modular malware platform. Published indicators include Internet Widgits Pty Ltd self-signed certificates and OpenSSL Demo CA fingerprint.